Модель доступа AppArmor

Мандатное управление доступом в Linux

Авраменко Давид Андреевич

2026-10-24

Содержание (i)

1. Введение

2. Принципы AppArmor

3. Администрирование

4. Заключение

1. 1. Введение

1.1 Почему AppArmor актуален

Уязвимость в приложении может привести к злоупотреблению его полномочиями.

Стандартные права файловой системы не всегда ограничивают **конкретную программу**.

Важен принцип **минимально необходимых привилегий**.

AppArmor снижает последствия компрометации приложений

Цель: изучить механизм разграничения доступа AppArmor.

Задачи:

Разобрать отличие DAC и MAC.

Рассмотреть профили и режимы работы.

Показать настройку, контроль и ограничения механизма.

2. 2. Принципы AppArmor

2.1 DAC и MAC: два уровня контроля

DAC — дискреционный доступ

Права владельца, группы и остальных.

Разрешения **r**, **w**, **x**.

Контроль зависит от пользователя и файла.

MAC — мандатный доступ

Отдельная политика безопасности.

Ограничения действий приложения.

Разрешение MAC не отменяет проверку DAC.

Итог: доступ возможен только при прохождении всех применимых проверок.

```
profile report-reader /usr/local/bin/report-reader {
    #include <abstractions/base>
    /etc/report-reader/config.ini r,
    /var/lib/report-reader/input/** r,
    /var/log/report-reader/** rw,
    network inet stream,
}
```

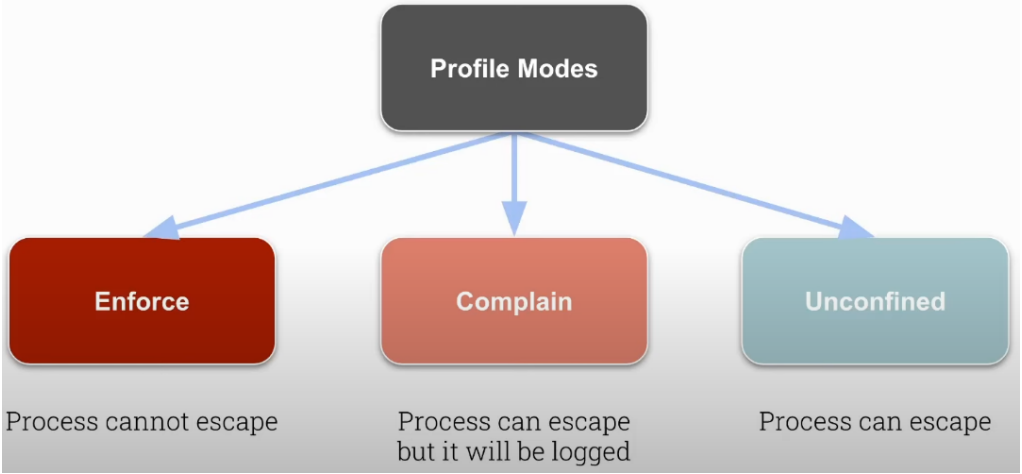
2.3 Что описывает профиль

Чтение конфигурации и входных файлов.

Чтение и запись журнала.

Отдельное разрешение сетевых сокетов.

Запрет операций вне разрешённой политики.


Profile Modes
Enforce
Complain
Unconfined
Process cannot escape
Process can escape
but it will be logged
Process can escape

`enforce` — реальная защита.

`complain` — отладка и уточнение правил.

`unconfined` — нет действующего ограничивающего профиля.

3. 3. Администрирование

```
student@localhost:~$ sudo aa-genprof /bin/rcat
Writing updated profile for /bin/rcat.
Setting /bin/rcat to complain mode.

Before you begin, you may wish to check if a
profile already exists for the application you
wish to confine. See the following wiki page for
more information:
http://wiki.apparmor.net/index.php/Profiles

Profiling: /bin/rcat

Please start the application to be profiled in
another window and exercise its functionality now.

Once completed, select the "Scan" option below in
order to scan the system logs for AppArmor events.

For each AppArmor event, you will be given the
opportunity to choose whether the access should be
allowed or denied.

[(S)can system log for AppArmor events] / (F)inish
```

Создание: **aa-genprof**.

Тестирование приложения.

Анализ событий: **aa-logprof**.

Переход в **enforce**.

```
sudo aa-status
sudo journalctl -k --grep=apparmor
sudo aa-logprof
```

aa-status — загруженные профили и режимы.

Журнал ядра — сообщения о запрещённых операциях.

aa-logprof — разбор событий и корректировка правил [@apparmor_audit_system].

Критерий	AppArmor	SELinux
Основной принцип	Профили приложений и пути	Метки безопасности и политика
Администрирование	Текстовые правила по ресурсам	Типы, домены, контексты
Особенность	Удобен для адресного ограничения программ	Гибкая модель системной политики

Оба механизма относятся к MAC и дополняют DAC.

Преимущества

Принцип минимальных привилегий.

Читаемые профили.

Режим обучения.

Интеграция с ядром Linux.

Ограничения

Защищаются лишь охваченные профилями процессы.

Профили требуют сопровождения.

Изменения путей могут нарушать правила.

Не заменяет обновления, DAC и сетевую защиту.

4. 4. Заключение

AppArmor ограничивает полномочия приложений и снижает ущерб при их компрометации.

Основа — профили MAC и проверки через LSM.

На практике важны режим **`enforce`** и корректные правила.

Эффективность зависит от полноты охвата процессов.

AppArmor — дополнительный уровень защиты Linux, а не замена остальных механизмов безопасности.